

Reflection

Abasiono Mbat (24120111121) · Group G · CYB 201 CA 1, Project G: SQLi dump + covert exfiltration
· October 2026

What I did

My part of the chain was the sqlmap step. I pointed sqlmap at the SQLi page of DVWA and let it work. After a few minutes it told me the id parameter was unsafe, and it named four ways it could be used: boolean blind, error based, time based, and UNION. I then asked it to dump the users table. Five accounts came out, each one protected by a plain MD5 hash. Hashing a password with MD5 and no salt is fast for the attacker, because the same word always makes the same hash.

On top of that, I built our group report. Captions, evidence table, the recommendations for the dev team, every figure number and every claim, I wrote or checked myself.

What went wrong

Three things broke on the way, and all three were mine rather than the tools.

- Before I started, I set my shell prompt to show my matric number, the way the guide asks. When it stayed there on every line I was sure the terminal had frozen. It had not. The prompt just stays until you close the window, and Ctrl+C never touches it, because Ctrl+C only stops a command that is still running.
- Next, john refused to run at all. The shell said command not found. I had typed it into the wrong terminal window, so the shell was reading a different state than the one I thought. Nothing was wrong with john.
- The most interesting one came last. john reported that it had cracked only two of the five passwords, which cannot be right when all five passwords sit in rockyou. The answer was in my own log: I had hit Ctrl+C during the prompt panic hours earlier and stopped the crack halfway. Running the same command again did the rest in seconds, because john keeps its progress. That gap between what a tool claims and what it should have done sent me to the log instead of the internet, which is where the answer was.

The guide is explicit that mistakes stay in the log, so I left all three in.

What I learned

Mostly I learned to distrust my first reaction. When a tool says it failed, the cheapest check is whether I mistyped, stopped it early, or aimed it at the wrong host, and my log answers all three in seconds.

Second, the credential dump taught me something about design rather than about hacking. admin and smithy had the exact same hash, so one recovered password opened two accounts. That single line is the whole argument for salted, slow hashes, and it is far more convincing than any paragraph I could write.

Third, my laptop cannot host the Metasploitable VM, so I rehearsed the whole chain against a small practice server on my own machine. I would do it the same way again,

but I would say up front in the write-up that the log came from the rehearsal and the lab target belonged to the rest of the group.

What I will do differently

Check the host and the tool version before the first command instead of after the first failure. Take the screenshots while the evidence is on screen, not an hour later from memory. And leave Ctrl+C alone.